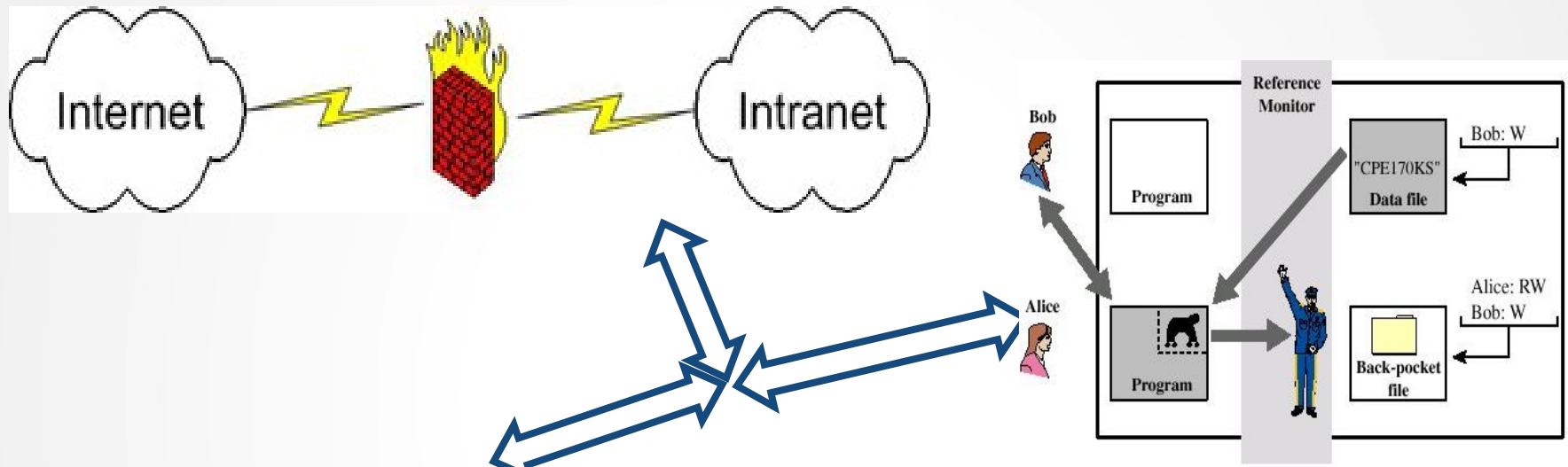


Security Techniques/ Access Control and Firewall



Firewall
Defense Policy
Access Control

	Program1	...	SegmentA	SegmentB
Process1	Read Execute		Read Write	
Process2				Read
.				
.				
.				

Access Control

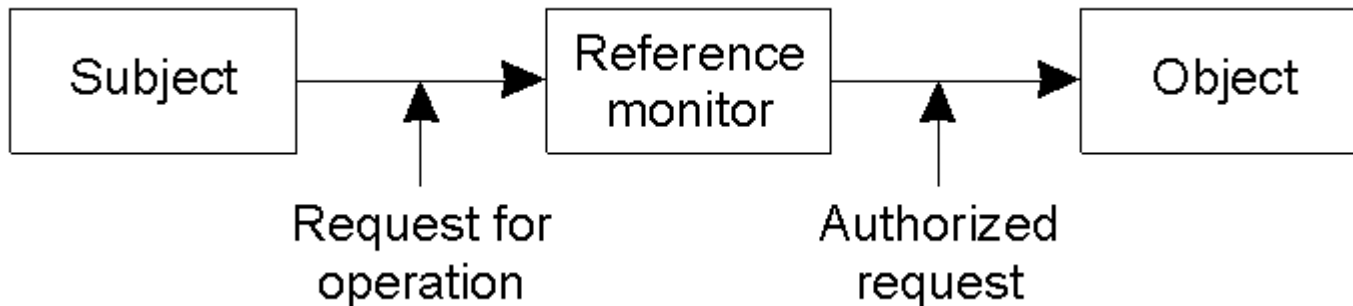
- ☐ is the practice of restricting access to resources only to authorized users, processes, or systems
- ☐ Used to identify a **user** to a system
- ☐ Associated with each **user**, there can be a profile that specifies permissible operations and accesses (authorization)
- ☐ The operating system can enforce rules based on user profile

Security Techniques/ Access Control

Access Control: Generalized View

≡ Access control: **Verifying** access rights to prevent misuse of resources

≡ Authorization: **Granting** access rights



Security Techniques/ Access Control

Access Control Model

General access control model

- Access Control **Matrix (ACM)**
- Access Control **List (ACL)**
- Capability **List (CL)**

Basic elements of ACM

- **Subject**: An entity capable of accessing objects, the concept of **subject** equates with that of **process**
- **Object**: Anything to which access is controlled (**files, programs, memory segments, ...**)
- **Access right**: The way in which an object is accessed by a subject (**read, write, execute, ...**)

Security Techniques/ Access Control

Access Control Matrix

	Program1	...	SegmentA	SegmentB
Process1	Read Execute		Read Write	
Process2				Read
•				
•				
•				

Security Techniques/ Access Control

Access Control Matrix

- In the ACM, each **subject** is represented by a **row** and each object as a **column**
- ACM $[s, o]$ lists precisely which operations subject s can request to be carried out on object o
- The drawback of this system is that the Matrix will have **many empty entries**
 - Another widely used approach is to use **Access Control Lists** in which each **object** maintains a list of **access rights of subjects**
 - Another approach is to give each subject a **Capability List** (access rights to objects) that are digitally signed

Security Techniques/ Access Control

Access Control Matrix - Example

	OS	Accounting Program	Accounting Data	Insurance Data	Payroll Data
Bob	rx	rx	r	-	-
Alice	rx	rx	r	rw	rw
Hana	rwX	rwX	r	rw	rw
Finance Sys.	rx	rx	rw	rw	rw

r = read w = write x = execute - =not allowed

≡**Subject** (Row): Three users (Bob, Alice, and Hana) and one program (Finance Sys.)

≡**Object** (Column): Five objects (OS, accounting Program, Accounting Data, Insurance Data, and Payroll Data)

≡**Access Rights** (each cell): Read, Write, Execute, Not Allowed)

Security Techniques/ Access Control

Access Control List

Decomposition of the matrix by columns

Access Control List for Program1: Process1 (Read, Execute)
Access Control List for SegmentA: Process1 (Read, Write)
Access Control List for SegmentB: Process2 (Read)

■ An access control list of an object lists **users** and their **permitted access right** on the object

■ The list may contain a default or public entry

Security Techniques/ Access Control

Capability List

Decomposition of the matrix by rows

Capability List for Process1:

Program1 (Read, Execute)

SegmentA (Read, Write)

Capability List for Process2:

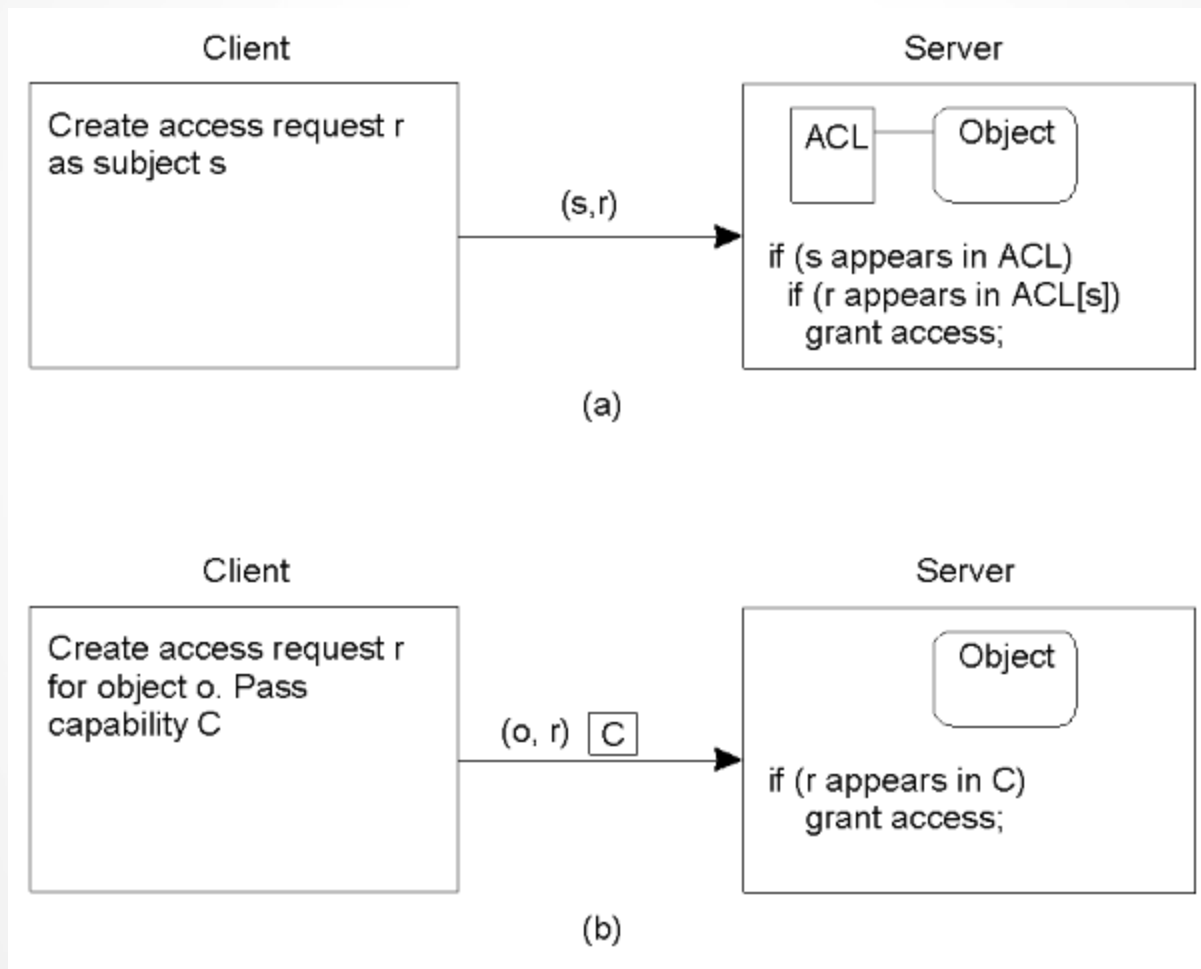
SegmentB (Read)

 A capability ticket of a user specifies **authorized objects** and **operations** for a user

 Each user has a number of such tickets

Security Techniques/ Access Control

Access Control List (a) Verses Capability List (b)



Security Techniques/ Access Control

Protection Domain

- An Access Control List or a Capability List can still become too large
- One way of reducing ACLs is to make use of protection domains
- A protection domain is a set of (object, access rights)
- Requests for carrying out an operation are always issued within a domain
- A user should be a member of a domain that has the required access rights to invoke an object

Security Techniques/ Access Control

Multilevel Security

≡ Multilevel security (E.g.. Military)

- Protection of data and resources on the basis of levels of security
- Users can be granted access to certain categories of data based on their level in their community (commanders, generals, ...)

≡ A multilevel secure system must enforce **security policies** like:

- **No read up:** A subject can only read an object of less or equal security level (**Simple Security Property**)
- **No write down:** A subject can only write into an object of greater or equal security level (***-Property**)

Security Techniques/ Access Control

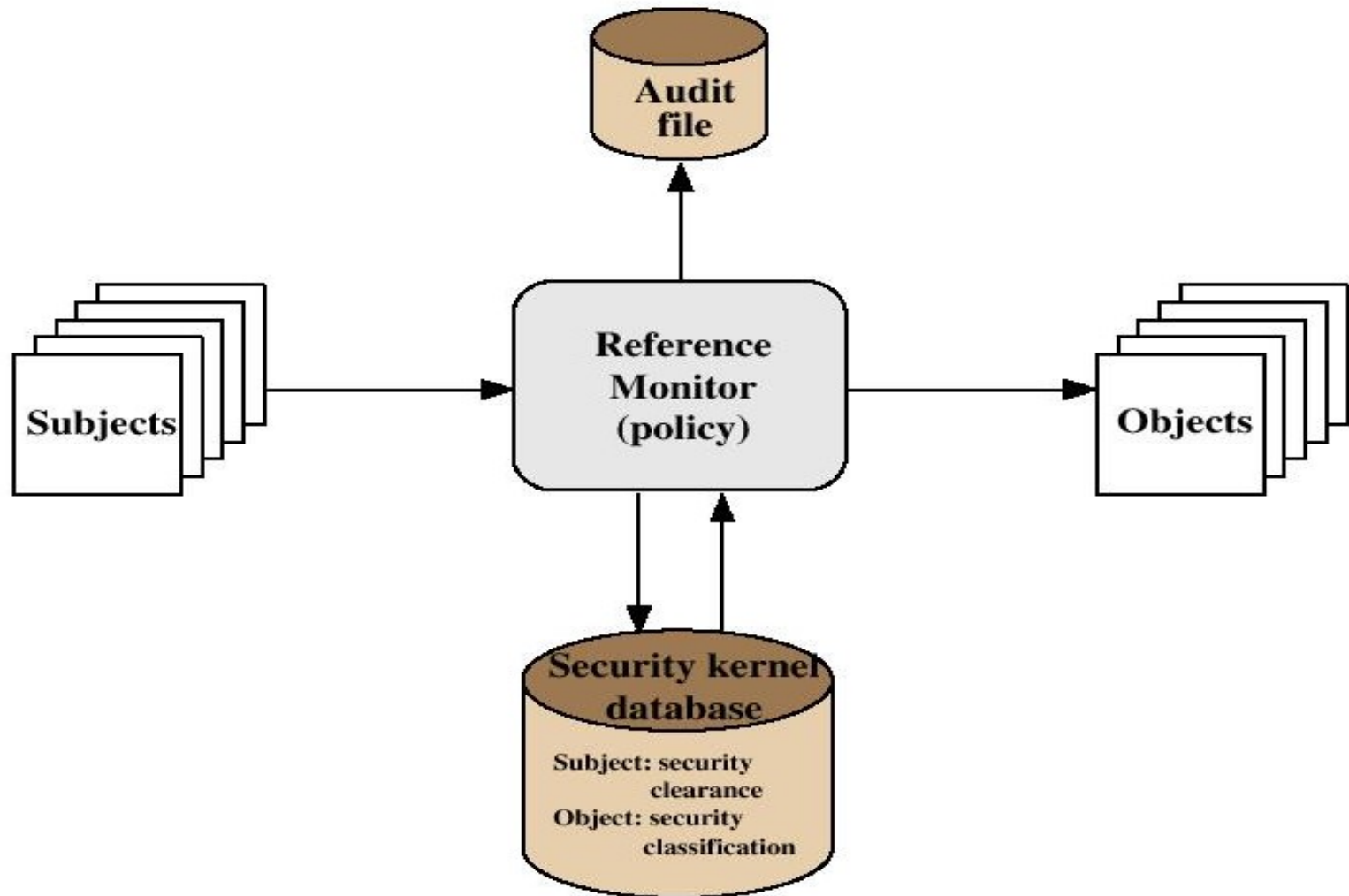
Trusted System: Reference Monitor (Implementing policies)

Reference Monitor

- Controlling element in the hardware and operating system that regulates the access of **subjects** to **objects** on the basis of **security parameters**
- The monitor has access to a **security kernel database**
- The monitor enforces the security policies (**no read up, no write down, etc.**)

Security Techniques/ Access Control

Trusted System: Reference Monitor Concept



Security Techniques/ Access Control

Trusted System: Reference Monitor Properties

☰ Properties of the Reference Monitor

- **Complete mediation:** Security rules are enforced on every access
- **Isolation:** The reference monitor and its database themselves are protected from unauthorized modification
- **Verifiability:** The reference monitor's correctness must be provable

☰ A system that can provide such verifications is referred to as a **trusted system**

Security Techniques/ Access Control

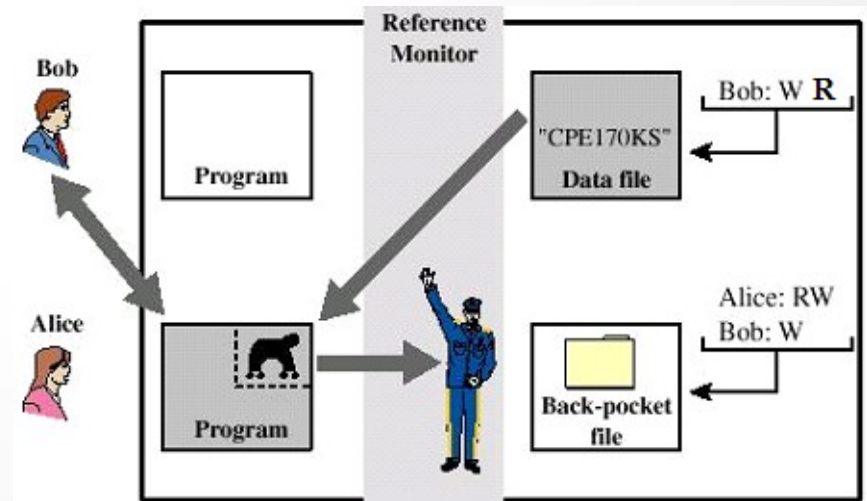
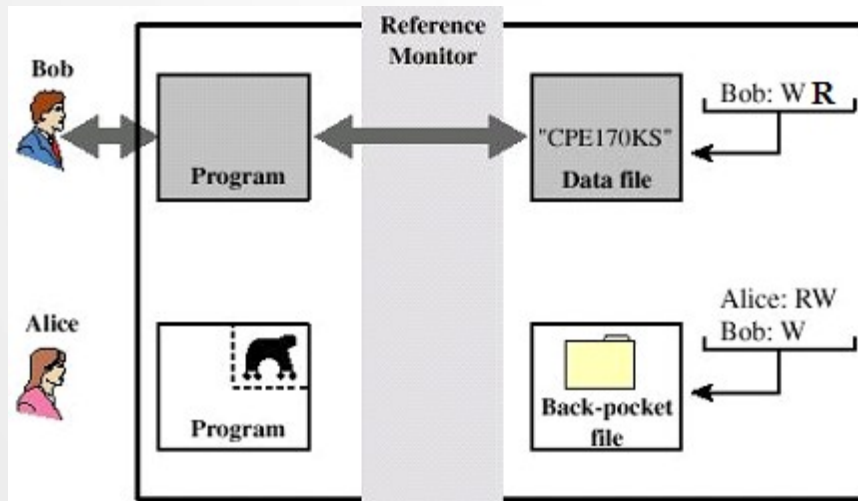
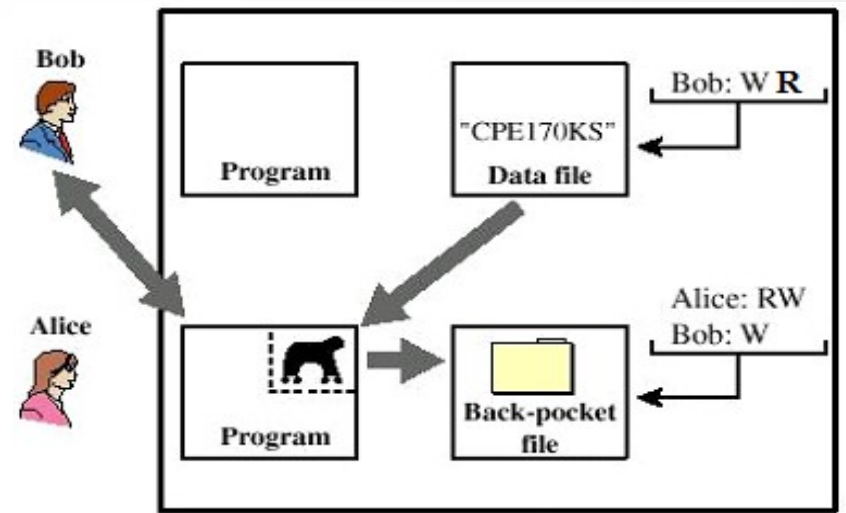
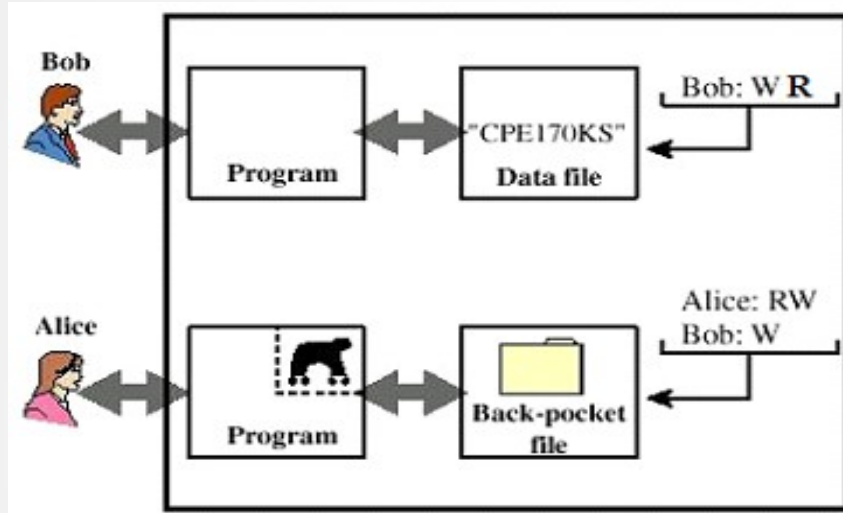
Trojan Horse and Trusted Systems

☐ **Secure and trusted** operating systems are one way to secure against Trojan Horse attacks on access control.

☐ **Trojan Horse** is used to get around the standard security mechanism used by most file management and operating systems

Security Techniques/ Access Control

Trojan Horse Attack: Bob with sensitive and Alice with public security levels



Guard!

Security Techniques/ Access Control

Access Control Policies and Models

≡ **Security policy** governs a set of rules and objectives needed by an organization.

- A **security model** can be used by an organization to help express the policy or business rules to be used in a computer system.
- Access control policies are high-level requirements that specify how access is managed and who may access information under what circumstances.
- For instance, policies may pertain to resource usage within or across organizational units or may be based on need-to-know, competence, authority, or obligation.
- There are two types of access control models:
 - **Discretionary** Access Control Model and
 - **Non Discretionary** Access Control Model

Security Techniques/ Access Control

Access Control Policies

■ **Discretionary Access Controls (DACs)** is an access policy determined by the owner of an object. The owner decides who is allowed to access the object and with what privileges.

- They are called discretionary as users can be given the ability of **passing on** their privileges of any of the objects under them to other users, without the intervention of the system administrator.
- DAC requirements have been perceived as being technically correct for commercial and civilian government security needs, as well as for single-level military systems.

■ **Non Discretionary Access Controls (NDACs)** are controls that cannot be changed by users, but only through administrative action. NDAC has three popular forms of access control policies:

- **Mandatory Access Control (MAC),**
- **Role-Based Access Control (RBAC) and**
- **Temporal Authorization (TA).**

Security Techniques/ Access Control

Access Control Policies

- **Mandatory Access Control (MAC)** is a means of restricting access to objects based on the sensitivity of the information contained in the objects and the formal authorization of subjects to access information of such sensitivity.
 - In MAC, decisions are made by a central authority, not by the individual owner of an object, and the owner cannot change access rights.
 - An example of MAC occurs in military security, where an individual data owner does not decide who has a Top Secret clearance, nor can the owner change the classification of an object from Top Secret to Secret.
- **Role-Based Access Control (RBAC)** bases access control decisions on the functions/roles of a user that he/she is allowed to perform within an organization.
 - This includes the specification of duties, responsibilities, and qualifications. For example, the role “individual associated with a hospital” can include doctor, nurse and patient.
 - In RBAC policy, the users cannot pass access permissions on to other users at their discretion.
- **Temporal Authorization** are formal statements of access policies that involve time-based access restrictions.

Security Techniques/ Access Control

Multilevel Security Models

Multilevel security

- Military-style classifications.
- Subjects and objects are often partitioned into different security levels.
- Protection is based on levels of security.
- A subject can only access objects at certain levels determined by its security level and model in use.

A multilevel Security Models

- Bell-LaPadula Model
- Biba Integrity Model

Security Techniques/ Access Control

Bell-LaPadula Model

≡ **Bell-LaPadula (BLP)** model is one of the first multilevel security models that was created to control access to data.

≡ For instance, if we have two levels of security namely **unclassified** and **top secret**:

- Unclassified personnel cannot read data at top-Secret levels and
- Top-Secret data cannot be written into files at unclassified levels.

Security Techniques/ Access Control

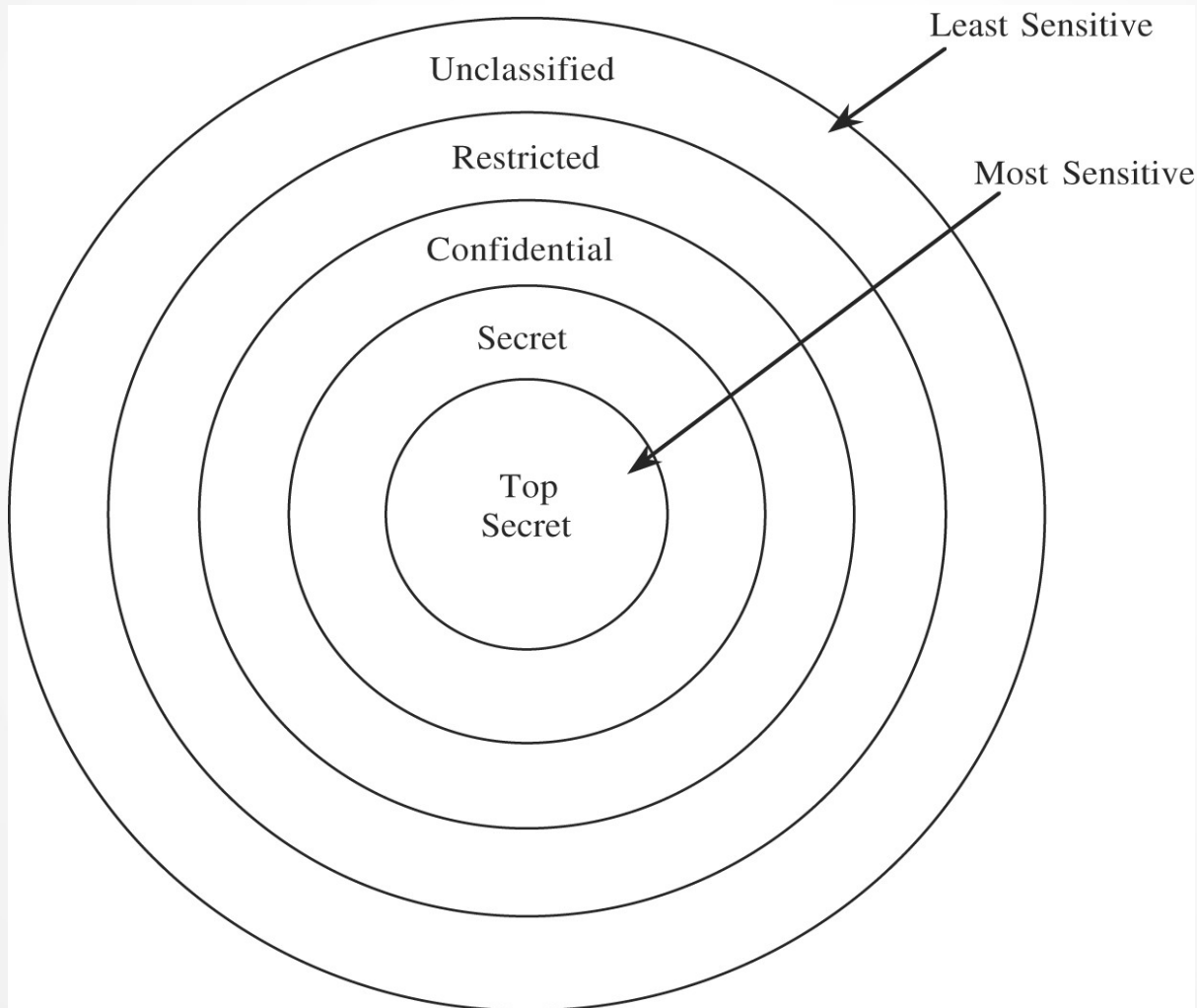
Bell-LaPadula Model ...

☰ The two basic properties of the Bell-LaPadula model are:

- “no read up” : A subject can only read an object of **less or equal** security level (Simple Security Property)
- “no write down”: A subject can only write into an object of **greater or equal** security level (*-Property) or (Star Property)

Security Techniques/ Access Control

Bell-LaPadula Model ...



**Hierarchy of
Sensitivity**

Security Techniques/ Access Control

Bell-LaPadula Model

Examples of security classification:

<i>security level</i>	<i>subject</i>	<i>object</i>
Top Secret	Registrar	Grade Files
Secret	Teacher	Assignment Solutions
Confidential	Students	Assignments
Unclassified	Everyone	Syllabus

Security level

Top Secret
Secret
Confidential
Restricted
Unclassified

Individuals

Thomas, Taye
Sally, Samuel
Claire, Chaltu
Rim, Roman
Ubang, Umer

Documents

Personnel Files
Electronic Mails
Activity Log Files
Email Address List
Telephone Lists

Security Techniques/ Access Control

Bell-LaPadula Model

- The Bell-LaPadula model supports **mandatory access control** by determining the access rights from the **security levels associated with subjects and objects**.
- It also supports **discretionary access** control by checking access rights from an **access matrix**.
- With respect to specification, we can consider the **multilevel** model as adding higher-level mechanisms to the access matrix model.
- In addition to supporting arbitrary access specifications to the access matrix, the model groups protected objects according to different security levels and decides user privileges by their authorized security clearance levels.

Security Techniques/ Access Control

Bell-LaPadula Model

Thus, an access request (**subj**, **obj**, **acc**) is granted if and only if all of the following properties are satisfied:

- **simple security property** (no read up): if **acc** is **read**, then $\text{level}(\text{subj})$ should dominate (greater than or equal to) $\text{level}(\text{obj})$
- ***-property** (no write down): if **acc** is **append**, then $\text{level}(\text{obj})$ should dominate $\text{level}(\text{subj})$;
- **discretionary security property**: the (**subj**, **obj**) cell in the matrix contains **acc**

Security Techniques/ Access Control

Biba Integrity Model

- ≡ A problem with BLP model is, it **does not deal with the integrity of data** as the *-property makes it possible for a lower level subject to write to a higher classified object
- ≡ The **inability** of the **BLP** model to deal with **integrity** of data motivated creation of the **Biba** model
- ≡ The **Biba integrity model** was published in 1977 at the Mitre Corporation, **one year** after the Bell La-Padula model was published.
- ≡ The **Biba** model addresses the problem with the *-property of the **Bell-LaPadula** model, which does not restrict a subject from writing to a more trusted object

Security Techniques/ Access Control

Biba Integrity Model – Access Modes

- ≡ The **Biba** model consists of the following access modes:
- **Modify:** the modify right allows a subject to write to an object. This mode is similar to the write mode in other models.
 - **Observe:** the observe right allows a subject to read an object. This command is synonyms with the read command of most other models.
 - **Invoke:** the invoke right allows a subject to communicate with another subject.
 - **Execute:** the execute right allows a subject to execute an object. The command essentially allows a subject to execute a program which is the object.

Security Techniques/ Access Control

Biba Integrity Model - Policies

- ≡ The Biba model is a family of different policies
- ≡ The goal of the model is to prevent the contamination of “clean” **high level** entities from “dirty” **low level** entities.
- ≡ The model supports both **mandatory** and **discretionary** policies

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

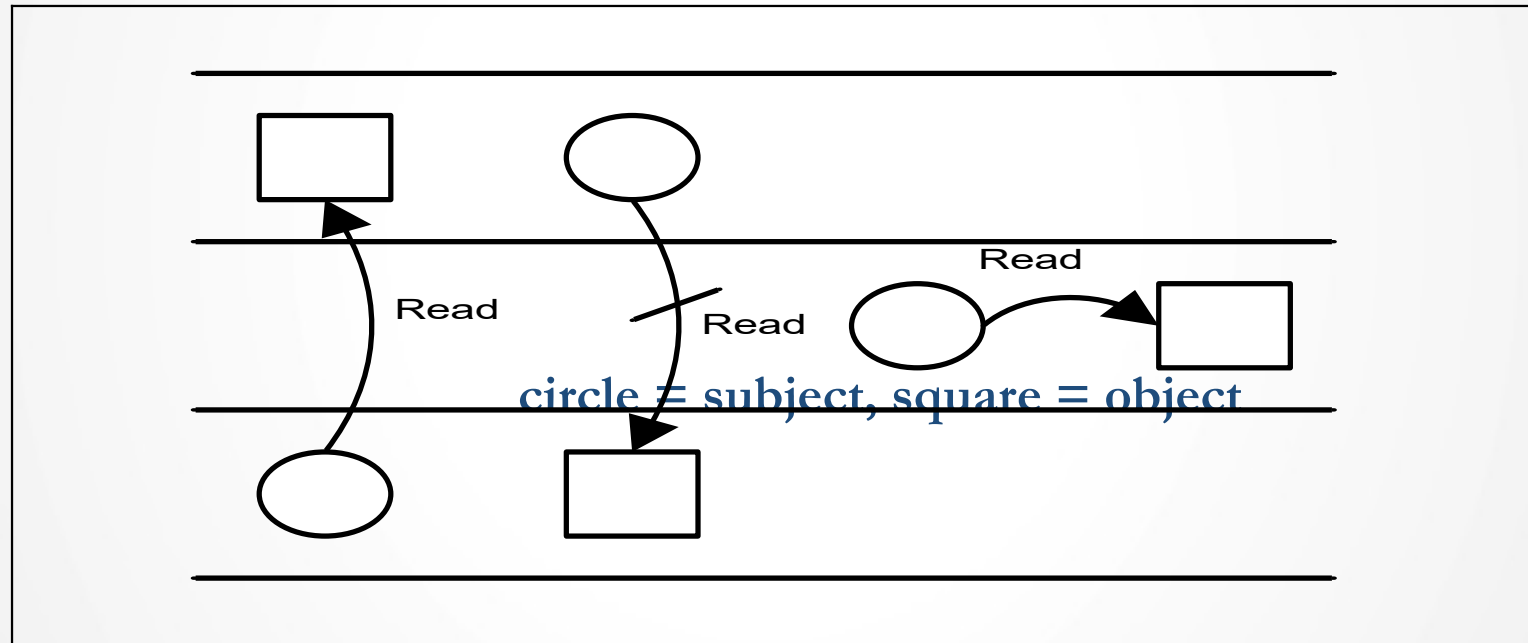
☰ Biba Strict Integrity Policy consists of:

- 1.Simple Integrity Property:** $s \in S$ can observe $o \in O$ if and only if $i(s) \leq i(o)$ (“no read-down”).
- 2.Integrity Star Property:** $s \in S$ can modify $o \in O$ if and only if $i(o) \leq i(s)$ (“no write-up”).
- 3.Invocation Property:** $s_1 \in S$ can invoke $s_2 \in S$ if and only if $i(s_2) \leq i(s_1)$ (“no upward invocation”).

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

Simple Integrity Property: “No Read-Down”

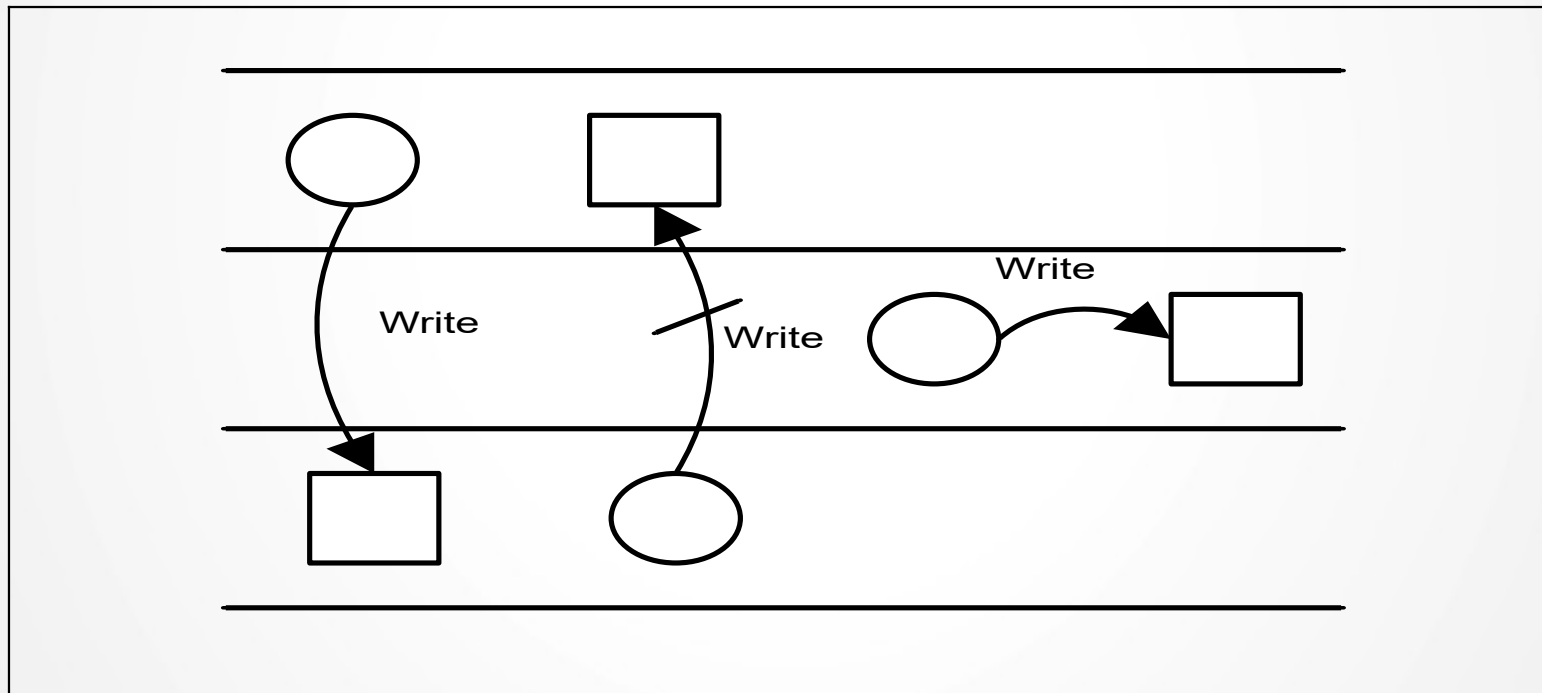


circle = subject, square = object

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

Integrity Star Property: “No Write-Up”

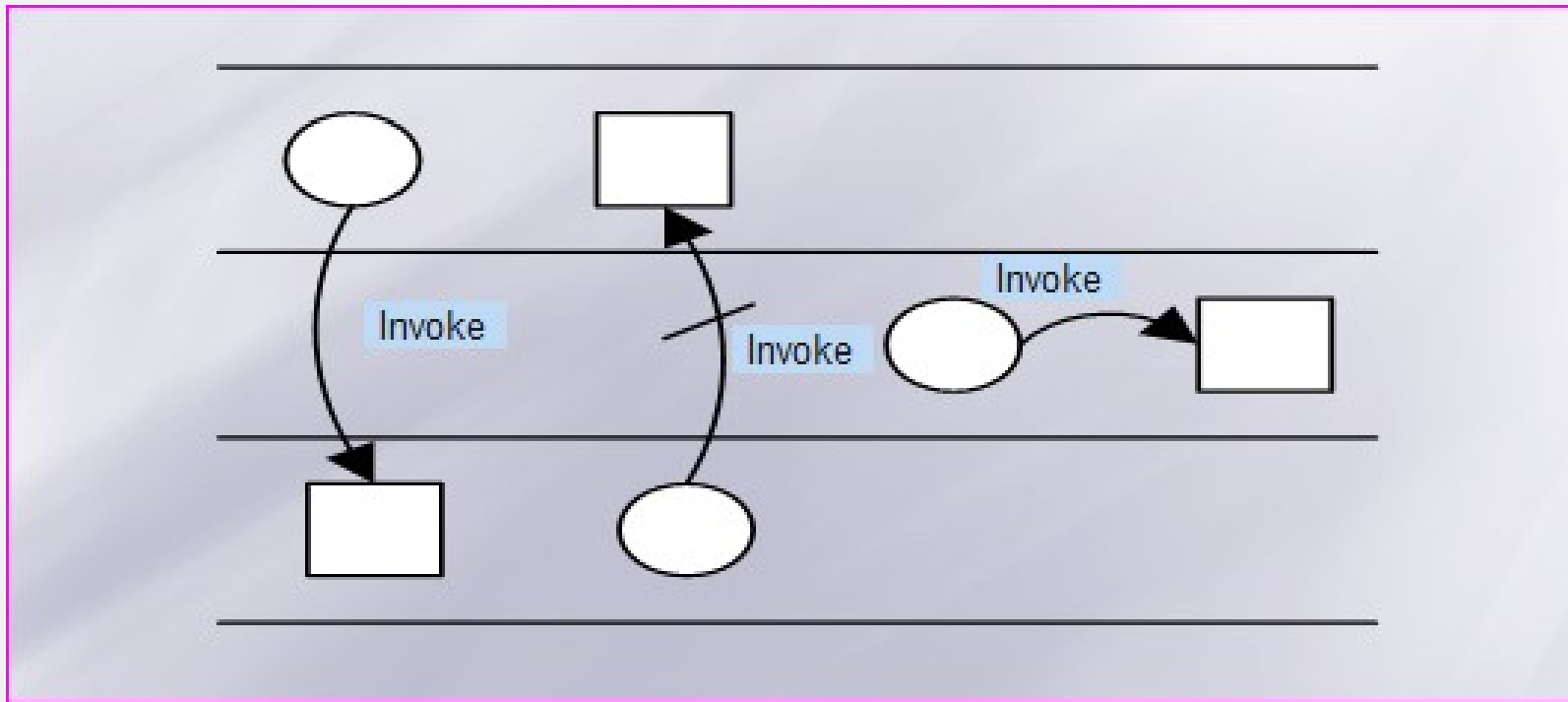


circle = subject, square = object

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

 Invocation Property: “No upward invocation”



circle = subject, square = object

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

- ≡ The Biba **strict integrity policy** enforces “no write-up” and “no read-down” on the data in the system, which is the opposite of the Bell-LaPadula model.
- ≡ This policy restricts the “**contamination**” of data at higher level, since a subject is only allowed to modify data at their level or at a lower level.
- ≡ The “no write-up” limits the damage that can be done by malicious programs in the system.
 - For instance, “no write-up” limits the amount of damage that can be done by a **Trojan Horse** in the system. The Trojan horse would only be able to write to objects at its integrity level or lower. This is important because it limits the damage that can be done to the **operating system**.
- ≡ The “no read-down” prevents a trusted subject from being “**contaminated**” by a less trusted object.

Security Techniques/ Access Control

Biba Integrity Model – Policies non-strict

≡ The low-watermark policy for subjects is a relaxed “no read-down”.

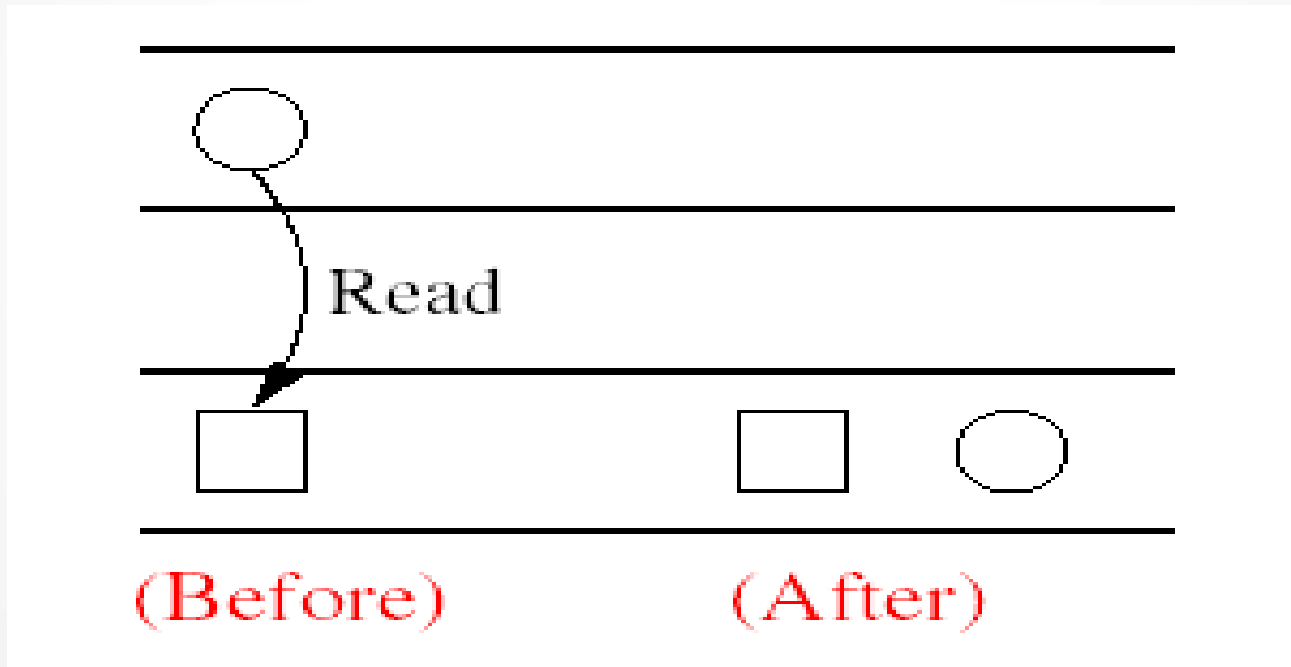
≡ The low-watermark policy for subjects contains these following rules:

1. **Integrity Star Property:** $s \in S$ can modify $o \in O$ if and only if $i(o) \leq i(s)$ (“no write-up”).
2. A subject may examine any object. If $s \in S$ examines $o \in O$ then $i'(s) = \min(i(s), i(o))$, where $i'(s)$ is the subjects integrity level after the read.
3. **Invocation Property:** $s \in S$ can invoke $s \in S$ if and only if $i(s_2) \leq i(s_1)$.

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

Low-Watermark Policy for Subjects



circle = subject, square = object

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

- The low-watermark policy for subjects does nothing to restrict a subject from reading objects.
- The low-watermark policy for subjects is a dynamic policy, because it lowers the integrity level of a subject based on what objects are observed.
- One problem with this policy is that if a subject observes a less trusted object, it will drop the subjects integrity level to that of the object. Then later, if the subject needs to legitimately observe other objects, it may not be able to do so because the subjects integrity level has been lowered. The effect of this would be denial of service depending on the timing of the submissions.

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

■ The low-watermark policy for **objects** is a relaxed “no write-down”.

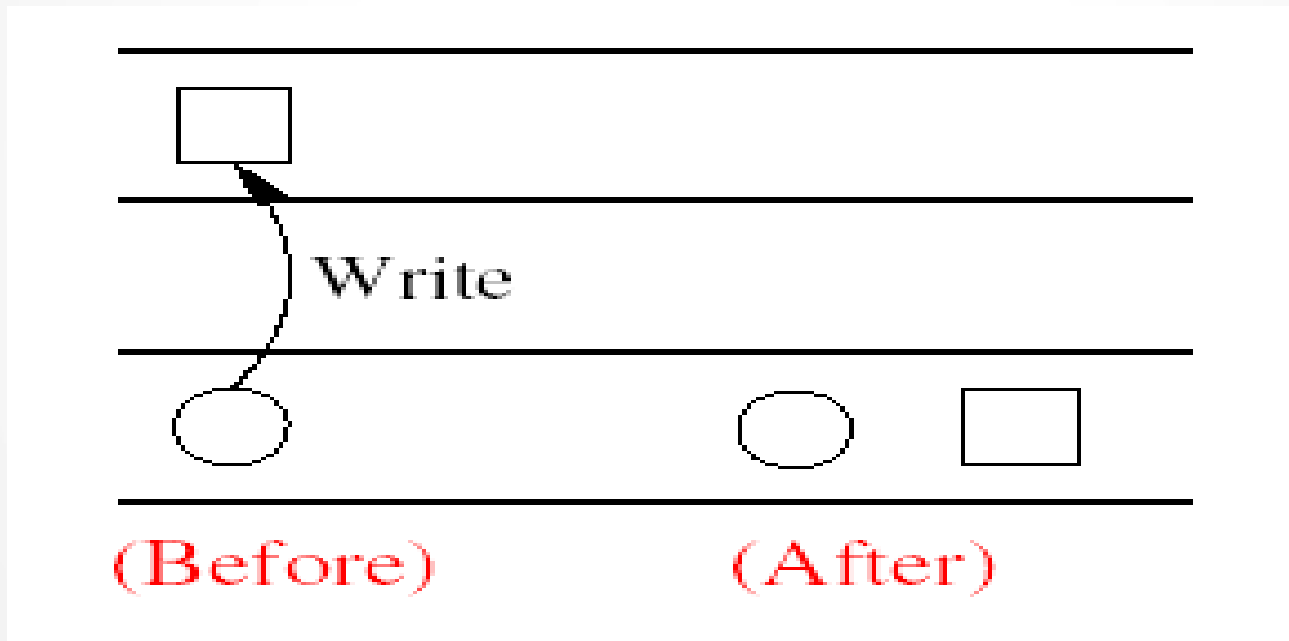
■ The following rules make up the low-watermark for objects policy:

1. $s \in S$ can modify any $o \in O$ regardless of integrity level.
2. If $s \in S$ modifies $o \in O$ then $i'(o) = \min(i(s), i(o))$, where $i'(o)$ is the objects integrity level after it is modified.

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

Low-Watermark Policy for Objects



circle = subject, square = object

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

- The **low-watermark policy for objects** is also a dynamic policy, similar to the low-watermark policy for subjects.
- The disadvantage of this policy is it does nothing to prevent an untrusted subject from modify a trusted object. In reality policy is not very practical.
- The policy provides **no real protection** in a system.
- The policy simply lowers in the trust placed in the objects. If a malicious program was inserted into the computer system it could modify any object in the system.
- This model would just lower the integrity level of objects that have become contaminated.

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

■ The **low-watermark integrity audit policy** consists of the following rules:

- Any subject may modify any object, regardless of integrity levels.
- If a subject modifies an object at higher integrity level (a more trusted object), it results in the transaction being recorded in an audit log.

■ The drawback to this policy is it does nothing to prevent an improper modifications of an object. This policy is similar to the low-watermark for objects policy, except in this case the objects integrity level is not lowered, it is recorded.

■ This policy simply records that an improper modification took place.

Security Techniques/ Access Control

Biba Integrity Model – Policies ...

- The **ring policy** is the last mandatory policy in the Biba model
- The Ring Policy consists of the following rules:
 - Any subject can observe any object, regardless of integrity levels.
 - Integrity Star Property: $s \in S$ can modify $o \in O$ if and only if $i(o) \leq i(s)$ (“no write up”).
 - Invocation Property: $s \in S$ can invoke $s' \in S$ if and only if $i(s_2) \leq i(s_1)$.
- The **Ring Policy** allows any subject to observe any object. This policy is only concerned with **direct modification**
- The drawback to this policy is it allows improper modifications to indirectly take place.
- A subject can read a less trusted object. Then the subject could modify the data it observed at its own integrity level.
- An example of this would be a user reading a **less trusted object**, then remember the data that they read and then at a later time writing that data to an object at their **own integrity level**.

Security Techniques/ Access Control

Biba Integrity Model - Conclusion

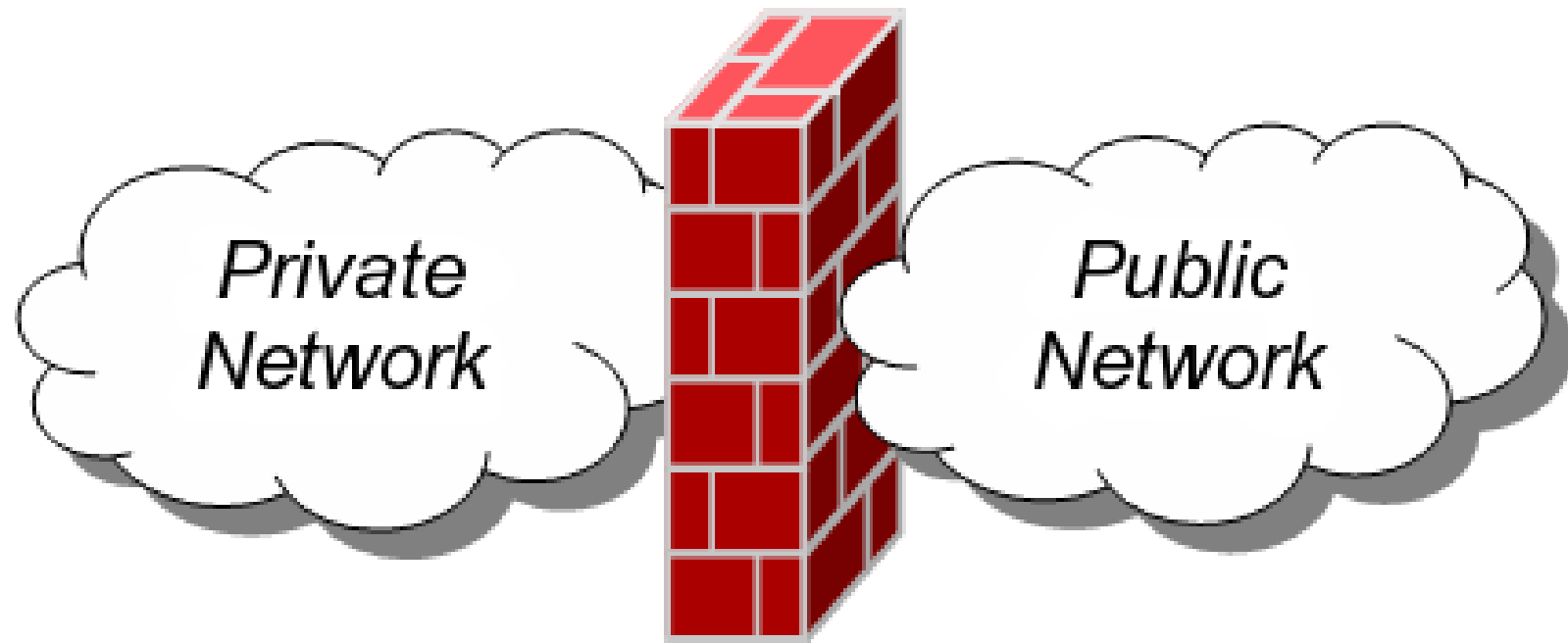
☰ The Biba model is a family of different models that can be selected

☰ The model should be combined with another model, because it does not provide **confidentiality**. A model such as the Bell-LaPadula should be used to complement it

☰ Read about:

- Clark-Wilson Model
- Chinese Wall Model
- Lipner Model

Security Techniques/ Firewall



Security Techniques/Firewall

What is Firewall?

- The term firewall has been around for quite some time and originally was used to define a barrier constructed to **prevent the spread of fire** from one part of a building or structure to another.
- Network firewalls provide a barrier between networks that prevents or **denies** unwanted or **unauthorized traffic**.
- **Definition:** A Network Firewall is a system or group of systems used to control access between two networks: a trusted network and an untrusted network, using pre-configured rules or filters.
 - Device that provides secure connectivity between networks (internal/external; varying levels of trust)
 - Used to implement and enforce a security policy for communication between networks
- Firewalls can either be **hardware and/or software** based.

Security Techniques/Firewall

What is Firewall? ...

- Firewalls can be composed of a **single router, multiple routers, a single host system or multiple hosts running firewall software, hardware appliances** specifically designed to provide firewall services, or any **combination thereof**.
- They vary greatly in design, functionality, architecture, and cost.
- A firewall is also called a **Border Protection Device (BPD)** in certain military contexts where a firewall separates networks by creating perimeter networks in a **DMZ “Demilitarized Zone”**.
- DMZ** is a sub network that contains organizations external facing services like Web services, Mail services, FTP Services, VoIP services etc.

Security Techniques/Firewall

Firewall History

Firewall technology emerged in the **late 1980s** when the Internet was a fairly new technology in terms of its global use and connectivity. The original idea was formed in response to a number of major internet security breaches, which occurred in the late 1980s.

First generation - packet filters

- The first paper published on firewall technology was in 1988, when Jeff Mogul from Digital Equipment Corporation (DEC) developed filter systems known as packet filter firewalls.

Second generation - circuit level

- From 1980-1990 two colleagues from AT&T Company, developed the second generation of firewalls known as circuit level firewalls.

Third generation - application layer

- Publications by Gene Spafford of Purdue University, Bill Cheswick at AT&T Laboratories described a third generation firewall. also known as proxy based firewalls.

Security Techniques/Firewall

Firewall Overview

- ≡ It is more feasible to secure a community of users by putting some control at the **entrance** rather than trying to secure every host
- ≡ This is done in the **real world**
 - **Countries** protect themselves at their borders
 - **Neighborhoods** protect the whole neighbors
- ≡ A **firewall** acts to provide secured access between two networks
- ≡ A firewall may be implemented as a standalone **hardware** device or in the form of a **software**

Security Techniques/Firewall

Firewall Overview ...

- ≡ The simplest kind of Firewall is a **packet filter**.
- ≡ A packet filter is a router that is augmented with an access control list, usually specified as a **list of rules**.
- ≡ When any packet is received by the router, the security rules are consulted to decide whether the packet should be **forwarded or dropped (ALLOW or DROP)**.
- ≡ A rule can specify which packets it will apply to, based on the header fields of the packets. For instance, the rule might specify source and destination IP addresses and port numbers and protocol names, or wild cards for each of these.

Security Techniques/Firewall

Firewall Overview ...

≡ Suppose that we've built a **security policy** and decided that we want to:

- allow **inbound** tcp connections to port 25 of mail server (1.2.3.4):

Allow tcp *: * → 1.2.3.4:25

- allow all **outbound** tcp connections:

Allow tcp {ourhosts}: * → *: *

- drop all the rest:

Drop *: * → *: *

Security Techniques/Firewall

Firewall Design goals

- ≡ All traffic from outside to inside must pass through the firewall (physically blocking all access to the local network except via the firewall)
- ≡ Only authorized traffic (defined by the local security policy) will be allowed to pass
- ≡ The firewall itself is immune to penetration (use of trusted system with a secure operating system)

Security Techniques/Firewall

Firewall Features

General

- Port Control
- Network Address Translation
- Application Monitoring
- Packet Filtering
- Data encryption
- Logging
- E-mail virus protection
- Popup advertisement blocking
- Spyware protection

Security Techniques/Firewall

Hardware Firewall

☰ Use one or more of three methods

- Packet filtering
- Proxy service
- State-full inspection

☰ It protects from

- Remote logins
- Application backdoors
- SMTP session hijacking
- Spam
- Denial of service
- E-mail bombs

Security Techniques/Firewall

Software Firewall

☐ It is a firewall that operate at the Application Layer of OSI

☐ Benefits

- Easier to track when a potential vulnerability happens
- Protect against new vulnerabilities before they are found and exploited
- Ability to "understand" application specific information structure
- Incoming or outgoing packets cannot access services for which there is no proxy

☐ Disadvantages

- Slows down network access dramatically
- More susceptible to distributed denial of service (DDOS) attacks
- Not transparent to end users
- Require manual configuration of each client computer

Security Techniques/Firewall

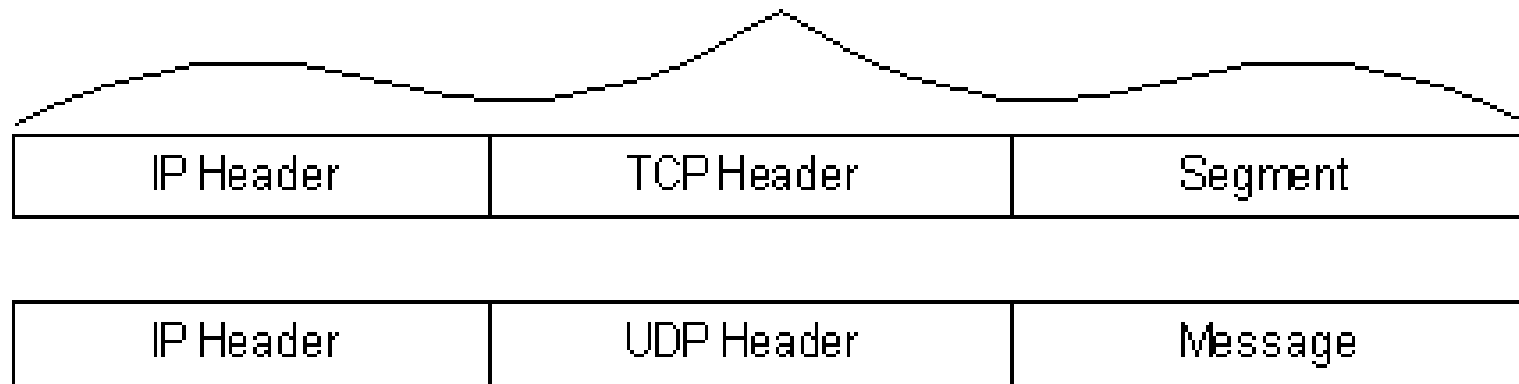
How Firewalls Work

- ☰ There are two security design logic approaches network firewalls use to make access control decisions.
 - Deny all: Everything, not specifically permitted, is denied.
 - Allow all: Everything, not specifically denied, is permitted.
- ☰ The one most often recommended is everything not specifically permitted is denied (deny all)

Security Techniques/Firewall

Basic TCP/IP Flow Review

Sample IP Packet



IP Header



Source IP
Address

Destination IP
Address

TCP Header



Source Port

Destination Port

UDP Header



Source Port

Destination Port

Security Techniques/ Firewall

Types of Firewalls

Security Techniques/ Firewall

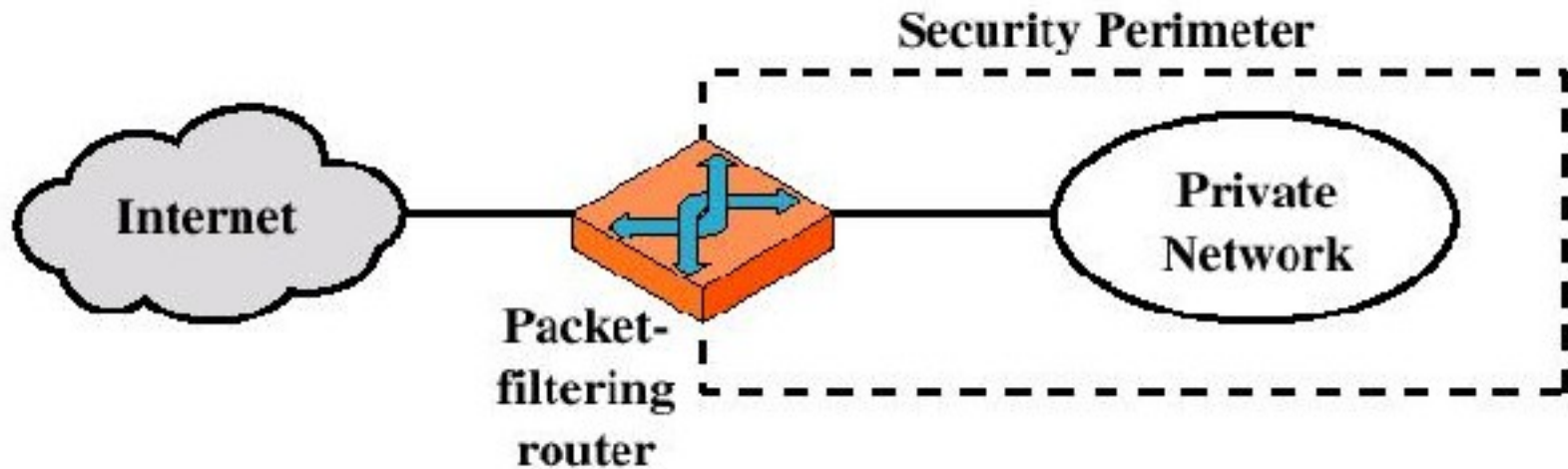
Types of Firewalls ...

1. By the Firewalls methodology :

- Packet Filtering
- Stateful Packet Inspection
- Application Gateways/Proxies
- Adaptive Proxies
- Circuit Level Gateway

Security Techniques/Firewall

Packet-filtering firewall



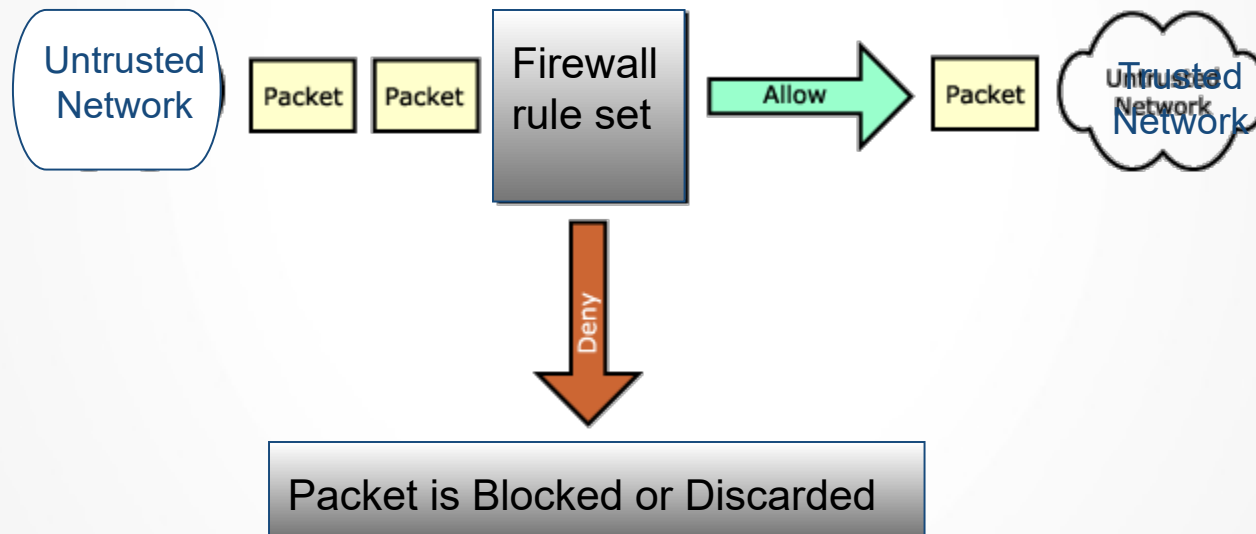
Security Techniques/ Firewall

Packet Filtering Firewall

- A packet filtering firewall does exactly what its name implies (it filters packets).
- As each packet passes through the firewall, it is examined and information contained in the header is compared to a pre-configured set of rules or filters.
- An allow or deny decision is made based on the results of the comparison.
- Each packet is examined individually regardless to other packets that are part of the same connection.

Security Techniques/ Firewall

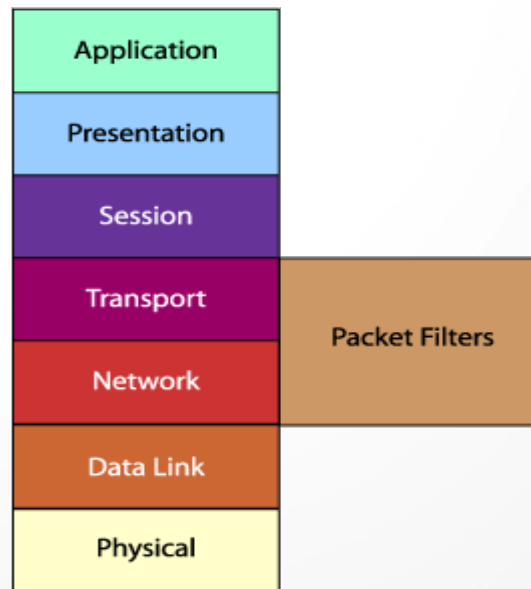
Packet Filtering Firewall ...



Security Techniques/ Firewall

Packet Filtering Firewall ...

☰ A packet filtering firewall is often called a network layer firewall because the filtering is primarily done at the network layer (layer three) or the transport layer (layer four) of the OSI reference model.



Security Techniques/ Firewall

Packet Filtering Firewall ...

- You use packet filters to instruct a firewall to drop traffic that meets certain criteria.
- For example, you could create a filter that would drop all ping requests.
- You can also configure filters with more complex exceptions to a rule.

Security Techniques/ Firewall

Packet Filtering Firewall ...

☰ Packet filtering rules or filters can be configured to allow or deny traffic based on one or more of the following variables:

- Source IP address
- Destination IP address
- Protocol type (TCP/UDP)
- Source port
- Destination port

Security Techniques / Firewall

Packet Filtering Firewall ...

☰ Advantages:

- Simplicity
- Transparency to users
- High speed

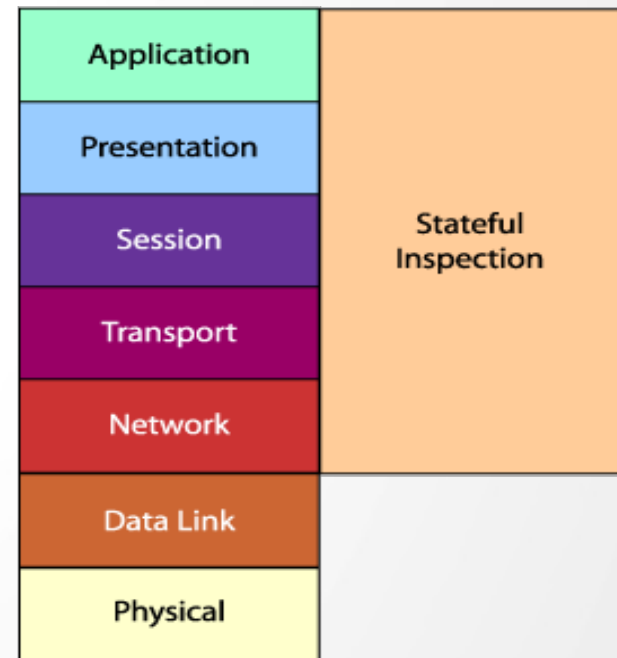
☰ Disadvantages:

- Difficulty of setting up packet filter rules
- Lack of Authentication

Security Techniques/ Firewall

Stateful Packet Inspection ...

- Stateful packet inspection uses the same fundamental packet screening technique that packet filtering does.
- In addition, it examines the packet header information from the network layer of the OSI model to the application layer to verify that the packet is part of a legitimate connection and the protocols are behaving as expected.



Security Techniques/ Firewall

Stateful Packet Inspection ...

☐ As packets pass through the firewall, packet header information is examined and fed into a dynamic state table where it is stored. The packets are compared to pre-configured rules or filters and allow or deny decisions are made based on the results of the comparison.

☐ The data in the state table is then used to evaluate subsequent packets to verify that they are part of the same connection.

Security Techniques/ Firewall

Stateful Packet Inspection ...

☰ This method can make decisions based on one or more of the following:

- Source IP address
- Destination IP address
- Protocol type (TCP/UDP)
- Source port
- Destination port
- **Connection state**

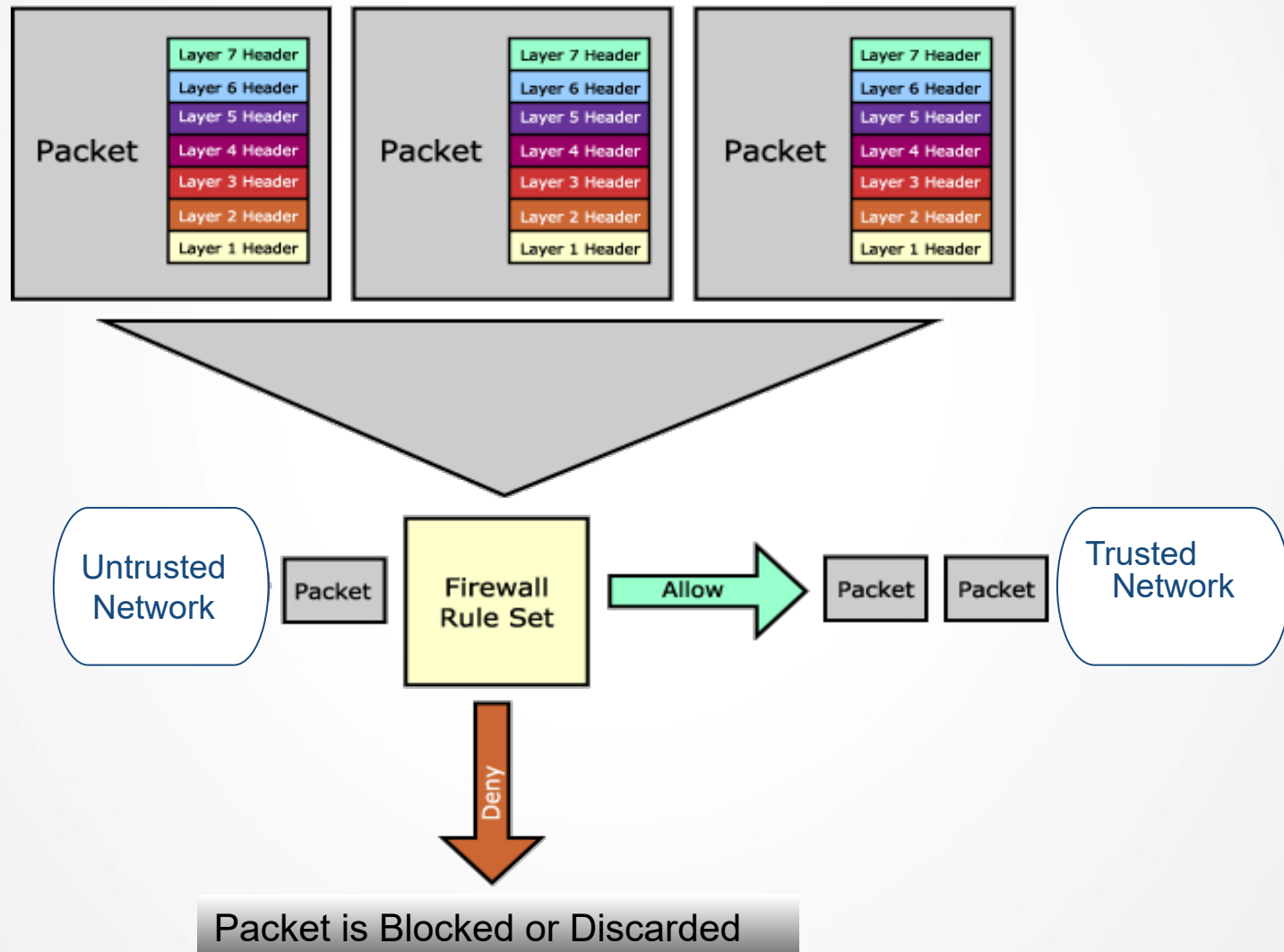
Security Techniques/ Firewall

Stateful Packet Inspection ...

- The **connection state** is derived from information gathered in previous packets.
- It is an essential factor in making the decision for new communication attempts.
- Stateful packet inspection compares the packets against the rules or filters and then checks the dynamic state table to verify that the packets are part of a valid, established connection.
- By having the ability to "remember" the status of a connection, this method of packet screening is better equipped to guard against attacks than standard packet filtering.

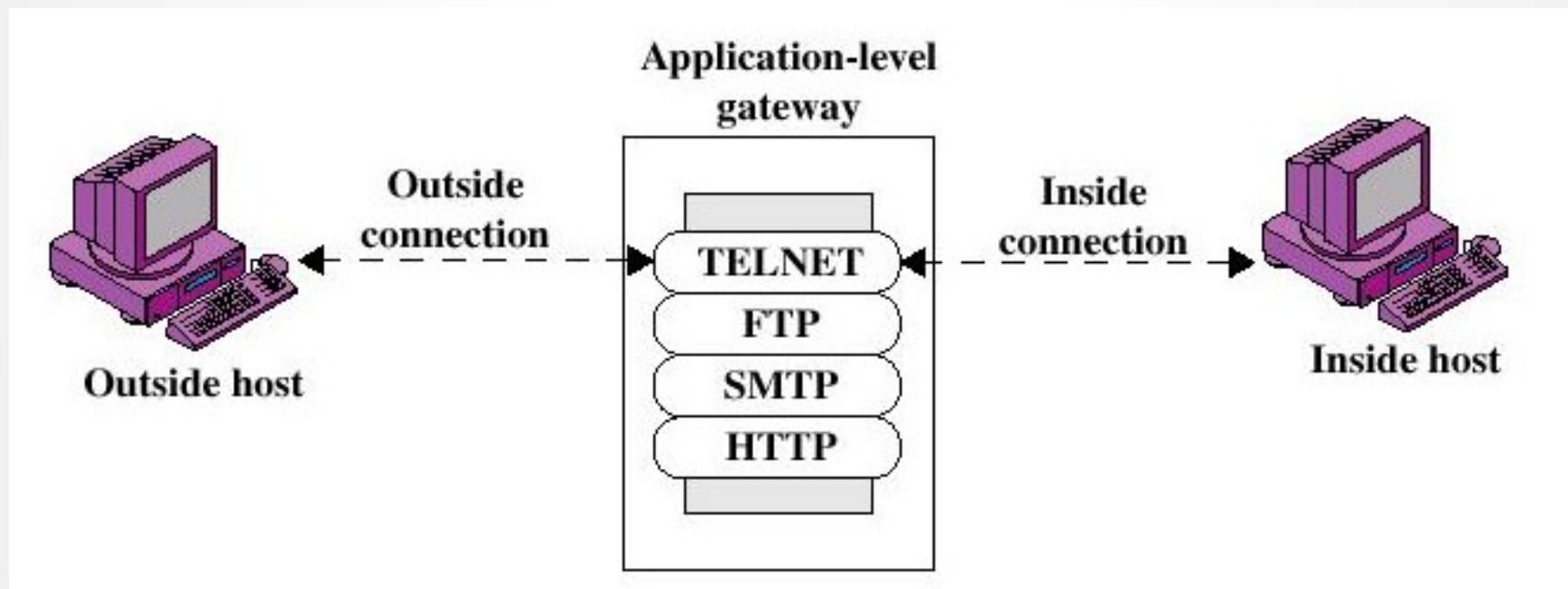
Security Techniques/ Firewall

Stateful Packet Inspection ...



Security Techniques/Firewall

Application-level Gateway/Proxies



- Also called proxy server
- Acts as a relay of application-level traffic

Application-level Gateway / Proxies

Advantages:

- Higher security than packet filters
- Only need to scrutinize a few allowable applications
- Easy to log and audit all incoming traffic

Disadvantages:

- Additional processing overhead on each connection (gateway as splice point)

Security Techniques/ Firewall

Application Level Gateways/Proxies

- The proxy plays middleman in all connection attempts.
- The application gateway/proxy acts as an intermediary between the two endpoints.
- This packet screening method actually breaks the client/server model in that two connections are required: one from the source to the gateway/proxy and one from the gateway/proxy to the destination.
- Each endpoint can only communicate with the other by going through the gateway/proxy.

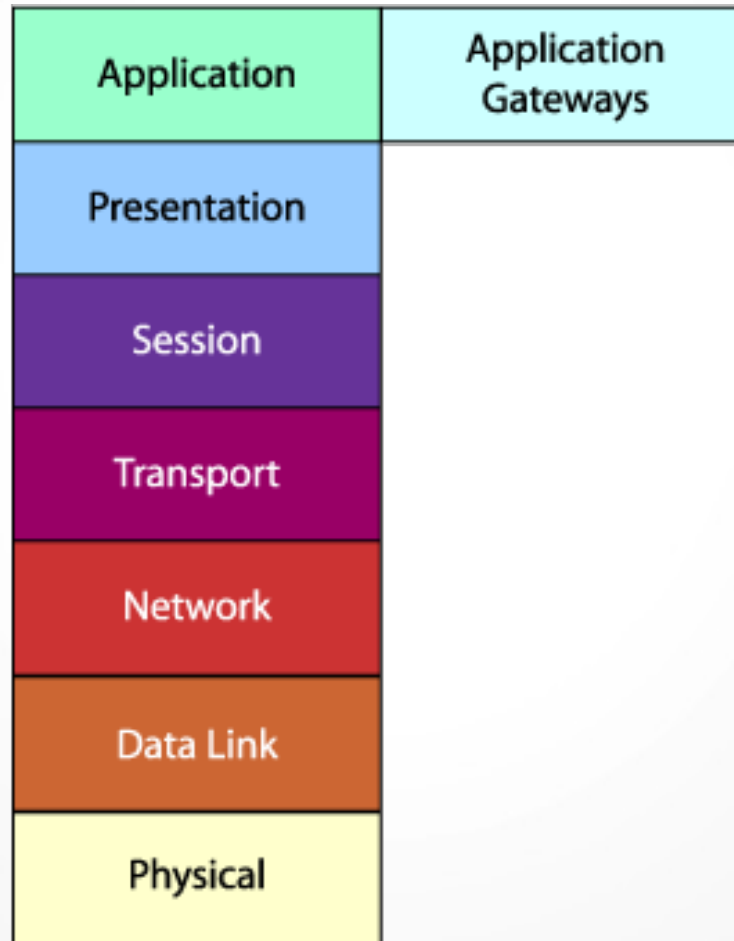
Security Techniques/ Firewall

Application Gateways/Proxies ...

- This type of firewall operates at the application level of the OSI model. For source and destination endpoints to be able to communicate with each other, a proxy service must be implemented for each application protocol.
- The gateways/proxies are carefully designed to be reliable and secure because they are the only connection point between the two networks.

Security Techniques/ Firewall

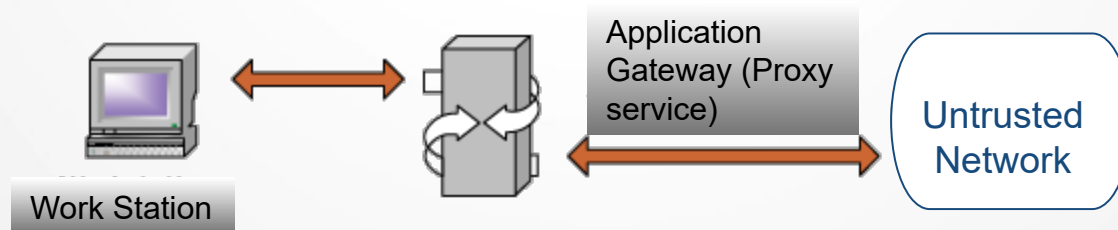
Application Gateways/Proxies ...



Security Techniques/ Firewall

Application Gateways/Proxies ...

- When a client issues a request from the untrusted network, a connection is established with the application gateway/proxy.
- The proxy determines if the request is valid (by comparing it to any rules or filters) and then sends a new request on behalf of the client to the destination.
- By using this method, a direct connection is never made from the trusted network to the untrusted network and the request appears to have originated from the application gateway/proxy.



Security Techniques/ Firewall

Application Gateways/Proxies ...

- The response is sent back to the application gateway/proxy, which determines if it is valid and then sends it on to the client.
- By breaking the client/server model, this type of firewall can effectively hide the trusted network from the untrusted network.
- It is important to note that the application gateway/proxy actually builds a new request, only copying known acceptable commands before sending it on to the destination.
- Unlike **packet filtering** and **stateful packet inspection**, an application gateway/proxy can see all aspects of the application layer so it can look for more specific pieces of information.

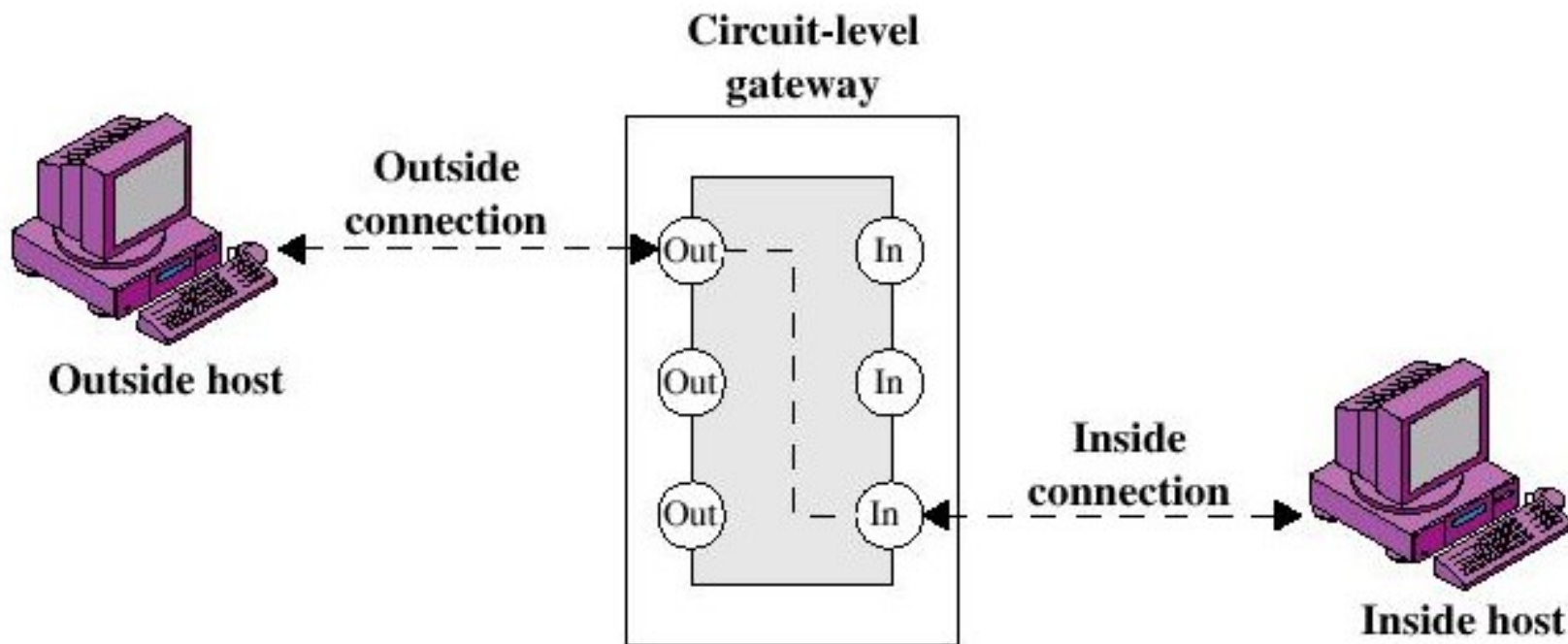
Security Techniques/ Firewall

Adaptive Proxies

- ☰ Known as dynamic proxies
- ☰ Developed as an enhanced form of application gateways/proxies. Combining the merits of both application gateways/proxies and packet filtering

Security Techniques/Firewall

Circuit-level Gateway



Security Techniques / Firewall

Circuit-level Gateway ...

Circuit-level Gateway

- Host based system or
- Specialized function performed by an Application-level Gateway
- Sets up two TCP connections
- The gateway typically relays TCP segments from one connection to the other
- The security function consists of determining which connections will be allowed

Security Techniques / Firewall

Circuit-level Gateway ...

- ≡ Unlike a packet filtering firewall, a circuit-level gateway does not examine individual packets. Instead, circuit-level gateways monitor TCP or UDP sessions.
- ≡ Once a session has been established, it leaves the port open to allow all other packets belonging to that session to pass. The port is closed when the session is terminated.
- ≡ Circuit-level gateways operate at the transport layer (layer 4) of the OSI model.

Security Techniques/ Firewall

Types of Firewalls

2. With regard to the scope of filtered communications

- Done between a single node and the network, or between two or more networks.
 - Personal Firewalls, a software application which normally filters traffic entering or leaving a single computer.
 - Network firewalls, normally running on a dedicated network device or computer positioned on the boundary of two or more networks.

Security Techniques/ Firewall

Types of Firewalls

3. Whether the firewalls keeps track of the **state** of network connections or treats each packet in isolation:

- Stateful firewall
- Stateless firewall

Security Techniques/ Firewall

Types of Firewalls ...

☰ Stateful firewall

- ☰ Keeps track of the state of network connections (such as TCP streams) traveling across it.
- ☰ Stateful firewall is able to hold in memory significant attributes of each connection, from start to finish.
- ☰ These attributes, which are collectively known as the state of the connection, may include such details as the IP addresses and ports involved in the connection and the sequence numbers of the packets traversing the connection.

Security Techniques/ Firewall

Types of Firewalls ...

☰ Stateless firewall

- ☰ Treats each network frame (Packet) in isolation. Such a firewall has no way of knowing if any given packet is part of an existing connection or is trying to establish a new connection.
- ☰ The classic example is the File Transfer Protocol, because by design it opens new connections to random ports.

Security Techniques/Firewall

Firewall Topologies

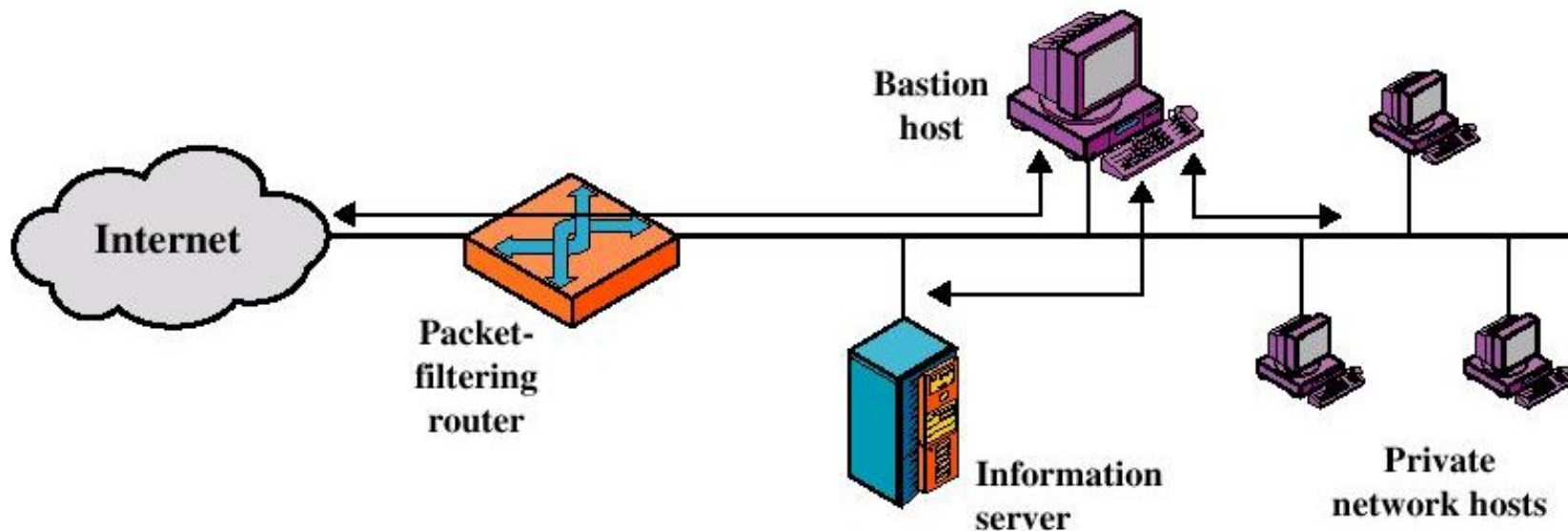
■ In addition to the use of simple configuration of a single system (single packet filtering router or single gateway), more complex configurations are possible

■ Common firewall Topologies/Configurations

1. Single-homed bastion host
2. Dual-homed bastion host
3. Screened-subnet firewall system

Security Techniques/Firewall

1. Screened host firewall system (single-homed bastion host)



Security Techniques / Firewall

☰ Screened host firewall, single-homed bastion configuration

☰ Firewall consists of two systems:

- A packet-filtering router
- A bastion host

Security Techniques / Firewall

☰ Configuration for the packet-filtering router:

- Only packets from and to the bastion host are allowed to pass through the router

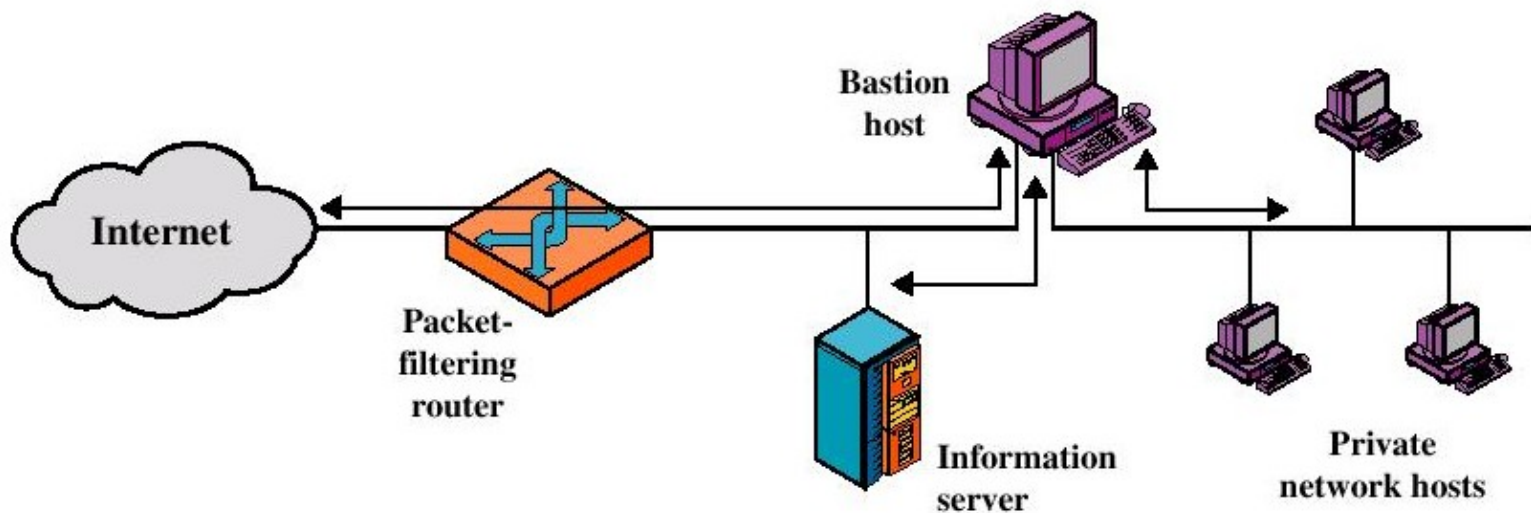
☰ The bastion host performs authentication and proxy functions

Security Techniques / Firewall

- Greater security than single configurations because of two reasons:
 - This configuration implements both packet-level and application-level filtering (allowing for flexibility in defining security policy)
 - An intruder must generally penetrate two separate systems

Security Techniques/Firewall

2. Screened host firewall system (dual-homed bastion host)



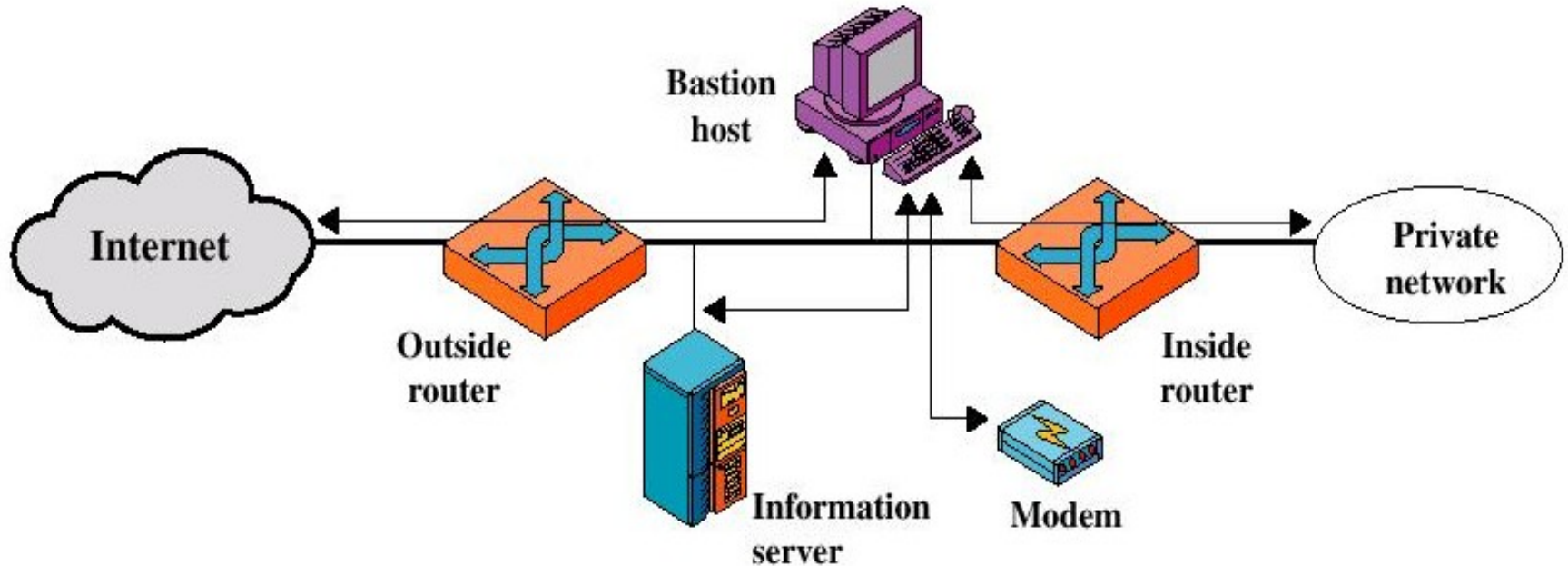
Security Techniques / Firewall

Screened host firewall, dual-homed bastion configuration

- The packet-filtering router is not completely compromised
- Traffic between the Internet and other hosts on the private network has to flow through the bastion host

Security Techniques/Firewall

3. Screened-subnet or DMZ firewall



Security Techniques/Firewall

Screened-subnet or DMZ firewall ...

- ☐ Most secure configuration of the three
- ☐ Creation of an isolated sub-network between two packet filtering routers.
- ☐ The exterior router is the only connection between the enterprise network and the outside world
- ☐ The interior router does the bulk of the access control work.
- ☐ The bastion host is a secure server. It provides an interconnection point between the enterprise network and the outside world for the restricted services

Security Techniques/Firewall

Screened-subnet or DMZ firewall ...

Advantages:

- Three levels of defense to thwart intruders
- The outside router advertises only the existence of the screened subnet to the Internet (internal network is invisible to the Internet)
- The inside router advertises only the existence of the screened subnet to the internal network (the systems on the inside network cannot construct direct routes to the Internet)

Security Techniques / Firewall

Intrusion Detection (ID)

- Firewalls generally don't detect internal attacks or attacks once the system is compromised
- An ID system gathers and analyzes information from various areas within a computer or a network to identify possible security breaches
- It detects both intrusions and misuse

Security Techniques/Firewall

Intrusion Detection (ID)...

Intrusion detection functions include

- Monitoring and analyzing both user and system activities
- Analyzing system configurations and vulnerabilities
- Assessing system and file integrity
- Ability to recognize patterns typical of attacks
- Analysis of abnormal activity patterns
- Tracking user policy violations

Security Techniques/Firewall

Summary

- Eliminate unnecessary services
- Apply all patches
- Public servers are vulnerable to attack
- Use a DMZ to provide layered defence
 - Place proxy servers in **DMZ**
 - Place **private** data/file/servers in **Intranet**
 - Use **default deny** for Internet-Intranet traffic and apply other firewall rules like in the example below:
allow TCP *:80 → <web server IP>:80
allow TCP *:443 → <web server IP>:443
deny all
- Add stateful inspection rules for known attacks (Code Red, Slammer, ...)
- Firewalls generally **don't detect** internal attacks or attacks once the system is **compromised**